

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Stakeholder Communication: Vendors, Customers, Partners, Regulators

1. Learning Objectives

By the end of this lecture, you will be able to:

- Identify the distinct communication needs of each stakeholder group — customers, vendors, partners, and regulators — during and after a cloud security incident.
- Describe the GDPR 72-hour supervisory authority notification requirement and the separate threshold for notifying data subjects.
- Explain the risks of delayed or incomplete incident communications and how proactive, phased disclosure typically produces better outcomes.
- Design pre-built notification templates and decision trees that can be activated under incident pressure without starting from scratch.
- Apply a structured audience-tiering model to ensure technical, operational, and executive communications are all accurate and appropriately scoped.

2. Introduction

Consider a mid-sized financial services firm that discovers, at 11 pm on a Thursday, that an attacker has exfiltrated customer account records from a cloud-hosted CRM platform. By midnight the security team has contained the breach. By 1 am the CISO has a preliminary scope estimate. By 6 am the legal team has confirmed that the event triggers GDPR notification obligations. The technical response is, at that point, largely under control. What is not under control is the communication challenge: four distinct audiences — a national data protection authority, approximately 14,000 affected customers, two integration partners whose pipelines touched the compromised system, and the firm's own executive committee — each expecting different information, at different levels of detail, delivered through different channels, within different timeframes.

This is the reality of stakeholder communication in cloud security operations. The technical response and the communication response run in parallel, not sequentially. Organisations that treat communication as something that happens after the incident is resolved consistently miss regulatory deadlines, damage customer relationships, and face avoidable regulatory scrutiny. Organisations that prepare their communication frameworks before incidents occur find that the actual notifications almost write themselves — because the hard decisions were made during planning, not during a 3 am crisis.

The CCSP exam tests your understanding of this domain from a practitioner's perspective: who gets notified, why, when, and in what form. The answers are not always intuitive, and several of the most testable concepts — particularly around regulatory timelines — are counterintuitive in ways that the exam exploits specifically.

3. Core Concepts Explained

3.1 Audience Tiering: Why One Message Fails Everyone

Definition: Audience tiering is the deliberate process of segmenting stakeholders by their relationship to the incident, their information needs, their authority level, and any regulatory obligations governing their notification.

Business relevance: A single incident notification drafted for the widest possible audience becomes simultaneously too technical for executives, too vague for regulators, and too alarming for customers. Each communication failure creates a separate downstream problem.

Practitioner angle: In practice, tiering means maintaining at least four parallel communication tracks: (1) regulatory, governed by statute and deadlines; (2) customer-facing, governed by empathy and clarity; (3) partner and vendor, governed by contractual obligations and shared-risk logic; and (4) internal executive, governed by decision-support needs.

Real-world example: In 2018, British Airways notified the UK Information Commissioner's Office of a data breach affecting approximately 500,000 customers. The regulator received a formal notification under GDPR. Customers received a direct apology with instructions to contact their bank and monitor statements. The press release addressed reputational concerns. Each track was distinct in content and channel.

Risks: Organisations that send the same notification to all audiences typically either over-disclose technical detail to customers (creating confusion and calls to support) or under-disclose to regulators (triggering follow-up enquiries and fines for non-compliance).

3.2 Regulatory Notification: Timelines, Thresholds, and Phased Disclosure

Definition: Regulatory notification is the formal, legally mandated process of informing a supervisory or government authority about a qualifying security incident within a prescribed period and in a prescribed format.

Business relevance: Under GDPR Article 33, a personal data breach must be reported to the competent supervisory authority within 72 hours of the controller becoming aware of it. This is not 72 hours from the start of the incident. It is 72 hours from the point at which the organisation knew — or reasonably should have known — that a breach had occurred. The distinction matters in audit and enforcement proceedings.

Practitioner angle: The 72-hour clock typically cannot accommodate a full forensic investigation. GDPR anticipates this: Article 33(4) explicitly states that where complete information is not available at the time of notification, it may be provided in phases, without undue further delay. The practical implication is that an initial notification should state known facts, acknowledge what is still under investigation, and commit to a follow-up timeline. Waiting for complete information before notifying is one of the most common — and most penalised — mistakes.

Real-world example: In multiple enforcement decisions by European data protection authorities, organisations have been fined specifically for late notification — not for the underlying breach

itself — because they delayed filing until their internal investigation was complete, which took weeks rather than the permitted 72 hours.

Additional jurisdictions: US state breach notification laws vary considerably but generally require notification to affected residents within 30 to 90 days, with some states (such as Florida) requiring notification within 30 days of determining that a breach has occurred. Healthcare organisations in the US must comply with HIPAA Breach Notification Rule timelines. Financial services firms face additional notification requirements under SEC rules and state financial regulators. Cloud security practitioners must map all applicable regimes to the jurisdictions in which their data subjects reside.

3.3 Customer Notification: Transparency as Risk Management

Definition: Customer notification is direct communication to individuals or organisations whose data or services may have been affected by an incident, informing them of the nature of the event, potential impact, and remediation steps available to them.

Business relevance: Under GDPR Article 34, when a personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the controller must communicate the breach to those individuals without undue delay. The threshold here is higher than for regulatory notification — not every breach that triggers supervisory authority notification also requires individual notification. The assessment of high risk is the controller's responsibility and must be documented.

Practitioner angle: Customers who receive prompt, clear, actionable communication about an incident affecting their data consistently report higher post-incident trust scores than customers who learn about an incident through media coverage. The communication should include: what happened (in plain language), what data was involved, what the organisation is doing, and what the customer should do. Avoid technical jargon and avoid minimising language that customers will later perceive as evasive.

3.4 Vendor and Partner Communication: Shared Risk, Contractual Obligations

Definition: Vendor and partner communication is the exchange of incident-relevant information with third parties who are part of the organisation's supply chain, have integration points with affected systems, or have contractual notification obligations under shared services agreements.

Business relevance: Many cloud security incidents involve the supply chain in one direction or the other. When the attacker gained access through a compromised third-party library or SaaS integration, the vendor needs to know so they can protect their other customers. When the cloud service provider has experienced a service disruption that affected your environment, their notification obligations to you are defined in the contract — typically in the incident notification clause of the Master Services Agreement or the SLA.

Practitioner angle: Vendor communication is often more constrained than customer communication in terms of what can legally be shared. Non-disclosure provisions in contracts may restrict the information you can provide, even to a vendor whose cooperation you need.

Legal review of what can be shared, and with whom, must happen before or alongside incident communications, not after.

4. Stakeholder Communication Comparison

Stakeholder	Typical Timeline	Primary Obligation	Content Focus	Key Risk if Delayed
Supervisory Authority (Regulator)	72 hours (GDPR)	Legal mandate (Article 33)	Nature, scope, categories affected, measures taken	Financial penalties; regulatory investigation
Data Subjects (Customers)	Without undue delay if high risk (GDPR Art. 34)	Legal mandate when high risk to individuals	Plain-language impact, what to do, org response	Media exposure; loss of trust; class actions
Cloud Service Provider	Per SLA/MSA terms	Contractual (SLA/MSA)	Technical detail of affected services; access logs needed	Delayed forensics; unresolved root cause
Integration Partners	Per contract; often 24–48 hours	Contractual (partnership agreement)	Affected APIs/pipelines; remediation status	Cascading incidents in partner systems
Executive Leadership	Immediately on awareness	Governance obligation	Non-technical summary; decisions required; reputational risk	Uninformed public statements; governance failures

5. Case Study and Incident Reference

Case Study: In 2023, a major US financial services company discovered that a former employee of a third-party cloud vendor had accessed customer data without authorisation. The firm faced simultaneous notification obligations under the GDPR (for EU resident customers), the CCPA (for California residents), and sector-specific SEC cybersecurity disclosure requirements. Each obligation had a different timeline, a different content standard, and a different recipient. The firm had pre-built templates for each regime, which allowed it to file all initial notifications within the applicable windows. Post-incident analysis found that having the legal team involved in template development before any incident occurred was the single most valuable preparation step. The templates themselves required only factual completion under pressure — the legal reasoning and structure were already approved.

Incident Reference: In the 2020 SolarWinds supply chain attack, affected organisations faced an unprecedented communication challenge: they had to notify regulators and stakeholders about a breach whose full scope remained unclear for months, because the attacker had used a trusted vendor's update mechanism. CISA guidance on the SolarWinds response explicitly acknowledged that phased, iterative disclosure was appropriate given

the evolving nature of the investigation — a real-world application of the phased disclosure model encoded in GDPR Article 33(4).

6. Analogy and Memory Anchor

Think of stakeholder communication during a security incident like a public utility managing a major power outage. The grid engineers receive continuous, technical status updates about which substations are affected and what repairs are underway. Residential customers receive a plain-language message about the expected restoration time and what they should do in the meantime. The energy regulator receives a formal incident report within the statutory period. Media inquiries go through a single spokesperson using pre-approved language. The underlying facts are the same for every audience, but the message is calibrated to what each audience needs to know and what they are going to do with the information. A power company that sent the engineering status update to residential customers, or the customer-facing message to the regulator, would face consequences from both. Cloud security communication works exactly the same way.

7. Exam Focus

The CCSP exam tests stakeholder communication primarily through scenario questions about what to do when an incident has just been discovered. The highest-yield topics are:

- GDPR 72-hour timeline: The clock runs from when the controller became aware of the breach, not from when the breach started. Know this distinction — it is tested directly.
- Regulators vs. data subjects: The threshold for notifying the supervisory authority (any personal data breach) is different from the threshold for notifying individuals (likely high risk to individuals). These are separate decisions with separate criteria.
- Phased disclosure: A timely, incomplete notification is better than a late, complete one. The exam will offer scenarios where waiting for full information seems logical — the correct answer is almost always to notify promptly and supplement later.
- Pre-built templates: Exam scenarios involving the question 'what should have been done before the incident' often have notification templates and stakeholder decision trees as the correct answer.
- Vendor-as-source vs. vendor-as-audience: If the attacker came in through a vendor, that vendor is both part of the root cause investigation and a notification recipient. The exam may test whether you understand both roles simultaneously.
- Common distractor: 'Wait until you know the full scope before notifying' is a consistently attractive wrong answer. It feels responsible. It is not. It violates regulatory requirements and is specifically cited in enforcement decisions.

8. Key Terms Glossary

Personal Data Breach: Any security incident resulting in accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data (GDPR definition).

Supervisory Authority: The national or regional data protection authority responsible for enforcing GDPR obligations; recipient of the 72-hour notification.

GDPR Article 33: The provision requiring controllers to notify the supervisory authority of a personal data breach within 72 hours of becoming aware, unless unlikely to result in risk.

GDPR Article 34: The provision requiring controllers to communicate a breach directly to individuals when that breach is likely to result in a high risk to their rights and freedoms.

Phased Disclosure: The practice of submitting an initial notification with available information, followed by supplements as investigation progresses; explicitly permitted under GDPR.

Master Services Agreement (MSA): The governing contract between a customer and a cloud service provider, typically including incident notification obligations and SLA terms.

Audience Tiering: Deliberate segmentation of stakeholders into distinct communication tracks, each receiving information calibrated to their needs and authority level.

Data Subject: Any identified or identifiable natural person whose personal data is being processed.

Notification Template: A pre-approved communication framework for a specific incident type and stakeholder audience, populated with factual details during an actual incident.

High Risk (GDPR Art. 34): A standard for assessing whether a breach requires individual notification; higher than the threshold for supervisory authority notification, considering likelihood and severity of harm.

Breach Notification Law: Any statute, regulation, or rule mandating that organisations notify affected parties of a qualifying data security incident within a defined period.

Spokesperson: The designated individual authorised to make public statements on behalf of the organisation during an incident; identified in advance as part of communication planning.

9. Quick Revision Checklist

- ☐ I can state the GDPR 72-hour notification timeline and identify when the clock starts.
- ☐ I can distinguish the threshold for notifying the supervisory authority from the threshold for notifying data subjects.
- ☐ I understand phased disclosure and why an early incomplete notification is preferable to a late complete one.
- ☐ I can name the four primary stakeholder groups and describe what each one needs from incident communications.
- ☐ I understand why vendor communication involves both notification and forensic cooperation.
- ☐ I can explain why 'wait for full information before notifying' is both legally risky and a known exam distractor.

- ☐ I know that pre-built notification templates and decision trees should exist before incidents occur.
- ☐ I can describe the role of a designated spokesperson in incident communication.
- ☐ I understand that US state breach notification laws and sector-specific frameworks impose parallel obligations to GDPR.
- ☐ I can apply audience tiering to draft appropriate communications for at least two different stakeholder groups from the same incident scenario.

10. Practice Questions

Q1 [SCENARIO]

SCENARIO: A cloud-hosted retail platform discovers at 09:00 Monday that an attacker accessed its customer database over the preceding weekend, exfiltrating names, email addresses, and hashed passwords for approximately 80,000 EU residents. The security team estimates the breach scope but notes that forensic analysis is not complete. The legal team confirms GDPR applies. Which of the following actions is most consistent with GDPR Article 33 obligations?

A. File a provisional notification with the supervisory authority by 09:00 Wednesday, stating known facts and acknowledging the ongoing investigation.

CORRECT. The 72-hour clock began when the organisation became aware at 09:00 Monday. Filing by 09:00 Wednesday meets the deadline. GDPR Art. 33(4) explicitly permits phased notification where complete information is unavailable.

B. Wait until the forensic investigation is complete before filing, to ensure the notification is accurate and comprehensive.

INCORRECT. This is the most common mistake. GDPR does not permit waiting for a complete investigation. The 72-hour window runs from awareness, not from investigation completion. Delayed notification has been specifically cited in enforcement fines.

C. Notify the affected data subjects first, then the supervisory authority, because customers have a higher stake in the outcome.

INCORRECT. Under GDPR, the supervisory authority is notified first (Art. 33). Data subject notification (Art. 34) is a separate obligation with a separate threshold — it applies only when the breach is likely to result in high risk to individuals.

D. Request a 30-day extension from the supervisory authority, as the investigation is not yet complete.

INCORRECT. GDPR does not provide for a general 30-day extension. The 72-hour window is mandatory unless the breach is unlikely to result in risk. Extensions are not available as a standard option.

Q2 [SCENARIO]

SCENARIO: A cloud security team discovers that an attacker gained initial access through a vulnerability in a third-party identity provider (IdP) integrated into their platform. The attacker moved laterally and accessed customer billing records. The CSP has confirmed no infrastructure-level compromise. The IdP vendor has not yet been contacted. Which of the following best describes the appropriate communication action regarding the IdP vendor?

A. Notify the IdP vendor so they can assess whether other customers are affected and whether a patch is available, while ensuring legal review of what information can be shared given contract terms.

CORRECT. The vendor is both a source of the compromise (whose other customers may be at risk) and a forensic resource. Legal review of contractual disclosure constraints must accompany — not delay — the communication.

B. Do not notify the IdP vendor until the internal investigation is fully complete, to avoid prejudicing your own forensic process.

INCORRECT. Delaying vendor notification risks leaving other customers exposed to the same vulnerability. Vendor cooperation may also be needed to understand the full scope of the breach. Delay creates more risk than transparency.

C. Notify the IdP vendor immediately and share all forensic findings, including customer data involved in the breach.

INCORRECT. Sharing customer data with a third-party vendor without legal review would likely violate data protection obligations. The notification should cover technical details of the compromise, not customer personal data.

D. Report the IdP vulnerability to CISA instead of the vendor, as federal agencies have responsibility for coordinating supply-chain disclosures.

INCORRECT. While CISA coordinates certain critical infrastructure disclosures, the primary obligation is to notify the vendor directly. CISA notification may be appropriate in parallel for critical infrastructure contexts, but is not a substitute for vendor communication.

Q3 [SCENARIO]

SCENARIO: A CISO at a healthcare technology company has been asked by the board to review the organisation's incident communication plan. The current plan requires all incident notifications to be drafted from scratch during an active incident. The board is concerned about regulatory risk. Which single improvement would most reduce the risk of late or non-compliant regulatory notifications?

A. Develop pre-approved notification templates for each applicable regulatory regime, covering GDPR, HIPAA Breach Notification, and relevant state laws, reviewed and approved by legal counsel before any incident occurs.

CORRECT. Pre-built, legally reviewed templates are the most effective way to reduce drafting time and legal risk during an actual incident. They allow factual population under pressure without re-litigating legal standards in real time.

B. Hire a dedicated incident communications manager who will be responsible for drafting all notifications during incidents.

INCORRECT. A skilled communicator is valuable, but without pre-approved templates, even an experienced manager must draft legal notifications under time pressure, increasing the risk of missed deadlines and non-compliant content.

C. Implement a SIEM with automated notification capabilities to alert regulators within 72 hours of any detected event.

INCORRECT. Automated SIEM alerts do not constitute regulatory notifications. Notifications must be human-authored, factually accurate, and meet specific content standards for each regime. An automated alert to a regulator would likely be non-compliant.

D. Require that all incidents be escalated to the CEO for sign-off before any notification is filed.

INCORRECT. CEO sign-off on every notification creates a bottleneck that can delay time-critical regulatory filings. Governance structures should allow the CISO or legal team to file notifications without requiring CEO approval for each one.

Q4

Under GDPR Article 34, which of the following conditions triggers the obligation to communicate a personal data breach directly to affected individuals?

A. Any personal data breach, regardless of risk level.

INCORRECT. This describes the threshold for supervisory authority notification under Article 33 (absent the exception where the breach is unlikely to result in risk). Individual notification has a higher threshold.

B. A breach that is likely to result in a high risk to the rights and freedoms of natural persons.

CORRECT. GDPR Article 34 requires direct notification to individuals only when the breach 'is likely to result in a high risk to the rights and freedoms of natural persons.' This is a higher and separately assessed threshold from the supervisory authority notification requirement.

C. A breach that has been reported to the supervisory authority within 72 hours.

INCORRECT. Meeting the supervisory authority notification obligation does not automatically trigger the data subject notification obligation. They have different thresholds and are assessed independently.

D. A breach involving more than 1,000 data subjects.

INCORRECT. GDPR does not define a numerical threshold of individuals affected. The test is the likelihood of high risk to individuals' rights and freedoms, which is qualitative, not quantitative.

Q5

A cloud security practitioner is reviewing their organisation's communication plan and discovers that the same notification template is used for all stakeholder groups. What is the primary risk of this approach?

A. It reduces the total number of notifications that need to be sent.

INCORRECT. Using a single template does not reduce the number of notifications. Each stakeholder group still requires its own communication. A single template simply makes each communication less appropriate for its audience.

B. It may result in over-disclosure of technical details to customers or under-disclosure of required information to regulators, as different audiences have different information requirements.

CORRECT. A single template cannot simultaneously meet regulatory content standards (which require specific legal elements), customer communication best practices (which require plain language and empathy), and executive needs (which require non-technical decision support). Each audience requires a tailored approach.

C. It increases the total cost of incident response.

INCORRECT. While the cost issue is plausible, the primary risk is not financial — it is that communications will be inadequate for at least some audiences, creating legal, reputational, or operational consequences.

D. It prevents the organisation from filing notifications within 72 hours.

INCORRECT. A single template does not inherently delay the filing. The problem is quality and appropriateness of the content, not timing.

Q6

Which of the following best describes 'phased disclosure' in the context of regulatory incident notification?

A. The practice of withholding notification until each phase of the forensic investigation is complete.

INCORRECT. This describes delayed disclosure, not phased disclosure. Waiting for investigation completion before notifying is a regulatory violation under GDPR's 72-hour requirement.

B. Filing an initial notification with available information within the required timeframe, then supplementing with additional details as the investigation progresses.

CORRECT. GDPR Article 33(4) explicitly provides for phased notification: the initial filing covers known facts and acknowledges unknowns, and further information is provided without undue further delay as it becomes available.

C. Notifying different regulatory bodies in a sequence based on jurisdiction size.

INCORRECT. Phased disclosure refers to how information is provided to a single regulator over time as it becomes available, not the sequence in which different regulatory bodies are notified.

D. A process by which the cloud service provider takes responsibility for the first phase of notification and the customer handles subsequent phases.

INCORRECT. Phased disclosure is about the timing and completeness of information provided in successive notifications. It does not describe a division of responsibility between the CSP and customer.

Q7

A cloud organisation's service level agreement with its CSP specifies that the CSP must notify the customer of any security incident affecting their environment within 24 hours. An incident occurs on Friday evening. Which of the following best describes the legal basis for this notification obligation?

A. GDPR Article 33, which requires cloud service providers to notify customers within 24 hours.

INCORRECT. GDPR Article 33 addresses controller-to-supervisory-authority notification. Processor-to-controller notification requirements are addressed in Article 33(2), which states processors must notify controllers without undue delay — but the 24-hour window in this scenario is contractual, not statutory.

B. The contractual terms of the Master Services Agreement or Service Level Agreement between the CSP and the customer.

CORRECT. CSP-to-customer incident notification obligations are typically contractual. They are defined in the MSA, SLA, or data processing agreement. The specific timeline (here 24 hours) is a negotiated contractual term, not a universal statutory requirement.

C. ISO/IEC 27001 certification requirements for cloud service providers.

INCORRECT. ISO 27001 is an information security management standard. It does not mandate specific notification timelines to customers. Certification to ISO 27001 does not create legal obligations around specific notification windows.

D. The shared responsibility model, which assigns notification to the CSP for all infrastructure-layer incidents.

INCORRECT. The shared responsibility model defines operational boundaries but does not specify legal or contractual notification timelines. Those are addressed in the contract, not the shared responsibility framework.

Q8

Which of the following is MOST accurate regarding the content of a regulatory notification to a supervisory authority under GDPR when the full scope of a breach is not yet known?

A. The notification must include all affected individuals' identities before it can be filed.

INCORRECT. GDPR explicitly does not require notification of individual identities. The notification covers categories of data subjects, approximate numbers, and nature of the breach — and acknowledges unknowns where the full picture is unavailable.

B. The notification should state what is known, acknowledge what is not yet determined, and commit to providing additional information without undue further delay.

CORRECT. This is the phased disclosure model codified in GDPR Article 33(4). Filing a provisional, accurate-but-incomplete notification on time is legally preferred over a comprehensive notification filed late.

C. The notification should not be filed until a CISO-level sign-off confirms completeness.

INCORRECT. Requiring completeness before filing is the exact mistake that results in late notifications. Regulatory frameworks contemplate that investigations are ongoing and provide for subsequent supplemental notifications.

D. The notification is only required if the breach involves financial data.

INCORRECT. GDPR applies to any personal data, not just financial data. Any personal data breach that is not unlikely to result in risk to individuals requires supervisory authority notification, regardless of data category.

Q9

An organisation's incident response plan designates the head of marketing as the spokesperson for all external communications during a security incident. What is the primary governance risk of this designation?

A. Marketing spokespeople are legally prohibited from making public statements about security incidents.

INCORRECT. There is no legal prohibition on marketing personnel serving as spokespeople. The concern is practical and governance-related: marketing spokespeople may not have the technical accuracy or legal training to handle regulator or media enquiries about a security incident.

B. Statements made by a marketing spokesperson may be technically inaccurate, legally inadvisable, or inconsistent with regulatory notifications, creating additional liability.

CORRECT. Incident communications carry legal and regulatory implications. Statements that contradict regulatory filings, minimise the incident inappropriately, or make inaccurate technical claims can create additional regulatory, legal, or reputational exposure. Spokespeople for security incidents typically require legal and security team coordination.

C. External communications during a security incident are exclusively the responsibility of the CISO.

INCORRECT. The CISO may not be the appropriate external spokesperson in all cases. The designation depends on organisational structure and incident type. What matters is that whoever speaks externally does so with accurate, legally reviewed content.

D. Marketing spokespeople cannot access the technical details needed to answer regulatory enquiries.

INCORRECT. While access to technical detail is a practical concern, the primary governance risk is the potential for inaccurate or legally problematic public statements, not the spokesperson's access level.

Q10

Under the GDPR framework, which of the following correctly distinguishes the notification obligations for regulators versus data subjects in the event of a personal data breach?

A. Regulators must be notified only if more than 500 individuals are affected; data subjects must be notified for all breaches.

INCORRECT. GDPR uses no numerical thresholds. Regulatory notification applies unless the breach is unlikely to result in risk. Data subject notification requires likelihood of high risk. Neither threshold is numerical.

B. Regulators must be notified of personal data breaches within 72 hours unless unlikely to result in risk; data subjects must be notified only when the breach is likely to result in high risk to them.

CORRECT. This is the precise legal structure: Art. 33 (supervisory authority, within 72 hours, unless unlikely to result in risk) and Art. 34 (data subjects, without undue delay, when likely to result in high risk). These are independent assessments with different thresholds.

C. Both regulators and data subjects must always be notified simultaneously within 72 hours.

INCORRECT. Data subject notification is not required within 72 hours — it is required 'without undue delay' when high risk exists. And it is not required in all cases, only when the high-risk threshold is met.

D. Data subjects must be notified first, followed by regulators, because individual rights take priority over regulatory compliance.

INCORRECT. GDPR does not prescribe a sequence between regulator and data subject notification. The 72-hour clock for regulators and the 'without undue delay' requirement for data subjects are concurrent obligations, not sequential ones.